

Security Fundamentals · Section 10

Security Frameworks and Standards

By TOUCH DEN · November 11, 2026

Contents

What You Will Learn 1

Before You Start 1

1. Why Frameworks Exist 1

2. The NIST Cybersecurity Framework 2.0 2

3. The CIS Critical Security Controls 2

4. ISO/IEC 27001 and 27002 3

5. MITRE ATT&CK 3

6. Compliance vs. Security 4

7. Choosing Where to Start 4

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

What You Will Learn

- *Why security frameworks exist, and what they give you.*
- *The NIST Cybersecurity Framework 2.0, and its six functions.*
- *The CIS Critical Security Controls, a practical starting list.*
- *ISO/IEC 27001 and 27002, the international standard.*
- *MITRE ATT&CK, the shared language of attacker behavior.*
- *The difference between compliance and real security.*
- *How a small business can choose where to start.*

Before You Start

Read lessons 1 to 9. You now know the ideas (goals, risk, controls, ethics); this lesson shows the organized, published ways that professionals apply them, so you do not have to invent security from scratch. No programming is needed.

---

1. Why Frameworks Exist

A security program has dozens of moving parts: assets, risks, controls, people, processes. Left to invent it alone, every organization would miss something, and you could never compare one organization's security to another's. ***Frameworks*** *solve this. A security framework is a published, structured set of guidance, built by experts and refined over years, that tells you what to do and often how to organize it.*

Frameworks give you four things:

- ***Completeness:*** *a checklist so you do not forget whole areas (like "we had firewalls but no backups").*
- ***A common language:*** *so your team, your auditors, and your partners mean the same things.*
- ***Credibility:*** *following a recognized framework shows customers and regulators you take security seriously.*
- ***A starting point:*** *you adapt proven guidance instead of starting from a blank page.*

There are many frameworks, and they overlap; you do not use all of them. Some describe how to run a whole program (NIST CSF, ISO 27001), some are a prioritized list of controls (CIS), and one is a catalogue of attacker behavior (MITRE ATT&CK). This lesson introduces the main ones so you recognize them; the GRC course goes deep.

2. The NIST Cybersecurity Framework 2.0

*The **NIST Cybersecurity Framework** (CSF) is one of the most widely used. It was created by the United States' National Institute of Standards and Technology, is free, and is used worldwide. Its strength is a simple, memorable structure built around **six functions** that describe everything a security program does:*

Function	The question it answers
Govern	*Who is responsible, and what are our risks, roles, and policies?*
Identify	*What do we have, and what matters? (assets and risks)*
Protect	*How do we safeguard it? (controls, access, training)*
Detect	*How do we notice when something happens? (monitoring, logs)*
Respond	*What do we do during an incident? (containment, communication)*
Recover	*How do we return to normal? (backups, lessons learned)*

*Notice how these map onto ideas you already know: Identify is assets and risk (lessons 1–3), Protect is controls (lessons 6–8), Detect/Respond/Recover are the defensive courses later in the program. **Govern** was added in version 2.0 (2024) to stress that security is a leadership responsibility, not just a technical one. The six functions are a superb mental model: for any organization, you can ask "how are they doing on each of the six?" and quickly find the gaps.*

3. The CIS Critical Security Controls

*Where the NIST CSF describes what areas to cover, the **CIS Critical Security Controls** (from the Center for Internet Security) give a concrete, **prioritized list of specific things to do**, ordered so that the most effective come first. For someone asking "but what do I actually do on Monday?", CIS is the most practical answer.*

The current version has 18 controls, grouped so that a small organization can start with the first, highest-impact ones, such as:

- *Know your hardware and software (you cannot protect what you do not know you have).*
- *Protect data, and configure devices securely.*
- *Control accounts and access, and use MFA.*
- *Manage vulnerabilities (patching).*
- *Keep and monitor logs.*
- *Run awareness training.*
- *Have a backup and recovery capability.*

*CIS also defines **Implementation Groups**, tiers that tell a small business (IG1), a mid-sized one (IG2), or a large one (IG3) how far to go. This makes it approachable: a small shop implements IG1 and already blocks the large majority of common attacks, which echoes the lesson from earlier, ordinary, well-applied controls stop most attacks.*

4. ISO/IEC 27001 and 27002

***ISO/IEC 27001** is the leading international standard for information security management. Where NIST CSF is a flexible framework, ISO 27001 is a formal **standard you can be certified against**: an independent auditor checks your security management and, if it meets the requirements, issues a certificate recognized worldwide.*

*Its central idea is an **Information Security Management System (ISMS)**: not a product, but an ongoing, documented process for managing security based on risk, deciding what to protect, applying controls, checking they work, and improving, continuously. Its companion document, **ISO/IEC 27002**, is a detailed catalogue of controls to choose from.*

Why it matters: many larger companies, and many contracts, require their suppliers to be ISO 27001 certified. For a business that sells to such customers, certification is often a condition of doing business, not just a nice-to-have. It is more formal and more effort than the CIS controls, and it is usually a goal for a maturing organization rather than a first step.

5. MITRE ATT&CK

***MITRE ATT&CK** is different from the others: it is not a program framework or a control list, but a **detailed, public knowledge base of how attackers actually behave**, organized by the stages of an attack (reconnaissance, initial access, privilege escalation, lateral movement, and so on, the attack lifecycle from lesson 5).*

*For each stage it catalogues the specific **techniques** real attackers use, with descriptions, real-world examples, and, crucially, how to **detect and defend** against each. It is maintained from observation of actual attacks, so it reflects the real world, not theory.*

Why it is so valuable, especially for defenders:

- *It gives everyone a **common language** for attacker behavior ("we saw technique T-such-and-such") so teams and tools can communicate precisely.*
- *Defenders use it to **measure coverage**: which attacker techniques can we detect, and where are our blind spots?*
- *It connects attack to defense: for every technique an attacker might use, it suggests what to watch for.*

You will use ATT&CK heavily in the defensive courses (Security Operations, Detection Engineering, Threat Intelligence) and in red teaming. For now, know that when security people talk about "ATT&CK", they mean this shared map of how attacks work and how to catch them.

6. Compliance vs. Security

*Here is one of the most important distinctions in the whole field. **Compliance** means meeting the formal requirements of a framework, standard, or law, often to pass an audit. **Security** means actually being hard to attack. They overlap, but they are **not the same thing**, and confusing them is dangerous.*

- *You can be **compliant but insecure:** you ticked every box for the audit, but the controls are weak in practice, out of date, or ignored day to day. "We passed the audit" is not "we are safe". Many breached companies were certified at the time.*
- *You can be **secure but not (yet) compliant:** a small team with excellent, well-practised security habits that has not done the paperwork for a formal certificate.*

*The right way to see it: **compliance is a floor, not a ceiling.** Frameworks and standards are a valuable baseline and a way to prove diligence, but the goal is real security, not just a passing grade. A good professional uses frameworks to be thorough and to communicate, while never mistaking a certificate for safety. Regulations you may meet, such as **PCI DSS** (for handling card payments) or data-protection laws, are compliance requirements; treat them as a minimum you build real security on top of.*

7. Choosing Where to Start

With several frameworks, which do you use? They are complementary, not competing, and the answer depends on the organization.

- ***A small business asking "what do we do first?"** → start with the **CIS Controls, Implementation Group 1**. It is concrete, prioritized, and blocks most common attacks without overwhelming a small team.*
- ***An organization wanting to structure a whole program and talk to leadership** → use the **NIST CSF** and its six functions as the backbone, then fill it in with specific controls (often CIS).*
- ***A company that must prove its security to big customers or regulators** → work toward **ISO 27001 certification**.*
- ***A team building detection and defense** → use **MITRE ATT&CK** to guide and measure what they can catch.*

A common, sensible combination is: NIST CSF to organize the program, CIS controls to decide what to implement first, MITRE ATT&CK to guide detection, and ISO 27001 later if the business needs the certificate. You do not need to master these now. The goal of this lesson is that when you hear "we follow NIST CSF" or "they're ISO 27001 certified" or "that maps to ATT&CK", you know what each means and why it is there. The next lesson looks at the people who do this work: the roles and careers in security.

Common Mistakes

1. Trying to use every framework at once. *They serve different purposes and overlap. Pick what fits the need: a program model, a control list, a standard, or an attack map.*

2. Treating a framework as a magic checklist. *Frameworks guide thoroughness; they do not implement themselves, and ticking boxes is not the same as being secure.*

3. Confusing compliance with security. *Passing an audit is a floor, not a ceiling. Many breached companies were "compliant" at the time.*

4. Thinking standards are only for big companies. *CIS Implementation Group 1 is designed for small organizations and blocks most common attacks.*

5. Ignoring the Govern function. *Security is a leadership responsibility, not just a technical one. NIST CSF 2.0 added Govern to make this explicit.*

6. Mistaking MITRE ATT&CK for a program framework. *It is a knowledge base of attacker behavior for detection and defense, not a plan for running a whole security program.*

Summary

Framework	What it is	Best for
NIST CSF 2.0	Six functions: Govern, Identify, Protect, Detect, Respond, Recover	Structuring a whole program; talking to leadership
CIS Controls	A prioritized list of specific controls, with tiers (IG1–IG3)	Knowing what to do first
ISO/IEC 27001 / 27002	International standard you can be certified against; an ISMS	Proving security to customers and regulators
MITRE ATT&CK	Knowledge base of attacker techniques, with detection	Building and measuring detection and defense
Compliance vs. security	Meeting requirements vs. actually being hard to attack	Remember: compliance is a floor, not a ceiling

Check Your Understanding

1. Give two things a framework provides that inventing your own does not.
2. Name the six functions of the NIST CSF 2.0.
3. How do the CIS Controls differ in purpose from the NIST CSF?
4. What is an ISMS, and which standard is built around it?
5. What is MITRE ATT&CK, and who finds it most useful?
6. Explain "compliance is a floor, not a ceiling" in your own words.
7. A small shop asks where to begin. What do you recommend, and why?

Answers

1. Any two: completeness (a checklist so you don't miss areas); a common language; credibility with customers and regulators; a proven starting point.
2. Govern, Identify, Protect, Detect, Respond, Recover.
3. NIST CSF describes what areas a program should cover (a structure); the CIS Controls give a concrete, prioritized list of specific things to do, ordered by impact.
4. An Information Security Management System: an ongoing, documented process for managing security based on risk. ISO/IEC 27001 is built around it.
5. A public knowledge base of how attackers actually behave, organized by attack stage, with detection and defense guidance. Defenders (SOC, detection, threat intelligence) and red teams find it most useful.

6. *Meeting the formal requirements (passing an audit) is a minimum baseline, not the goal. You can be compliant yet insecure, so real security must be built on top of compliance, not mistaken for it.*
7. *Start with the CIS Controls, Implementation Group 1: it's concrete, prioritized, sized for a small team, and blocks the majority of common attacks.*

Practice

1. *Take any small organization (real or imagined) and write one sentence for each of the **six NIST CSF functions**, saying what it would mean for them (e.g. "Detect: we review login alerts each morning").*
2. *From the CIS-style starter list in topic 3, pick the **three controls** you think would most reduce risk for that organization, and say why.*
3. *In one or two sentences, describe a situation where an organization could be **compliant but insecure**.*

A Worked Example

For a small online shop:

1. *Govern: the owner sets a simple security policy and reviews risks each quarter. Identify: list every device, account, and the customer data we hold. Protect: MFA on all accounts, least privilege, encrypted database. Detect: alerts on large data exports and failed logins. Respond: a one-page plan naming who does what in an incident. Recover: nightly offline backups we test monthly.*
2. *Top three controls: MFA on all accounts (defeats stolen passwords), nightly tested backups (defeats ransomware), and patching/updates (closes the holes worms and exploits use). These block the most common serious attacks.*
3. *Compliant but insecure: the shop passed a card-payment audit a year ago, but since then it stopped applying updates and never tested its backups, so it holds a valid certificate while being wide open to ransomware.*

Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.